

GRC Program Project Charter

Project Title

NovaForge Manufacturing Governance, Risk, and Compliance (GRC) Program Implementation

Field	Value
Document ID	NF-GRC-001
Version	1.0
Classification	Internal
Author	GRC Analyst
Reviewer	CIO
Approver	CEO
Effective Date	July 1, 2026
Review Cycle	Annual

Project Sponsor

Chief Information Officer (CIO)

Project Manager - GRC Analyst

Background

NovaForge Manufacturing is a growing industrial robotics company that designs, manufactures, and supports automation systems for customers across North America. As the company expands, it must establish a formal Governance, Risk, and Compliance (GRC) program to protect its information assets, support business objectives, manage cybersecurity risk, and demonstrate compliance with applicable legal, regulatory, and contractual requirements. Rapid organizational growth, increasing customer expectations, expanding cloud adoption, and evolving cybersecurity threats have highlighted the need for a formal Governance, Risk, and Compliance (GRC) program. This charter authorizes the development of a structured governance framework to manage cybersecurity risk while supporting NovaForge Manufacturing's strategic business objectives.

Purpose

The purpose of this project is to design and implement a comprehensive Governance, Risk, and Compliance program that enables NovaForge Manufacturing to:

- Establish information security governance
 - Identify and assess organizational risks
 - Develop security policies and standards
 - Improve security maturity
 - Support regulatory and contractual compliance
 - Provide executive visibility into cybersecurity risk
-

Project Objectives

By the completion of this project, NovaForge Manufacturing will have:

- An established governance framework
 - A documented asset inventory
 - A comprehensive risk assessment
 - A centralized risk register
 - Information security policies
 - Vendor risk management procedures
 - Incident response documentation
 - Executive security reporting dashboards
 - Security metrics and KPIs
 - Control mapping aligned to NIST CSF 2.0
-

Project Scope

Included

- Corporate offices
- Manufacturing facilities
- Cloud services
- End-user devices
- Servers
- Network infrastructure
- Business applications
- Third-party vendors
- Security documentation
- Risk management processes

Excluded

- Physical implementation of security technologies
- Penetration testing
- Live production systems
- Software development
- Security operations center (SOC) monitoring

Key Stakeholders

Stakeholder	Responsibility
CEO	Executive sponsorship
CIO	Project sponsor
Security Manager	Security oversight
GRC Analyst	Project execution
IT Operations	Technical support
Engineering	Asset owners
HR	Personnel security
Legal & Compliance	Regulatory guidance
Department Managers	Risk ownership

Project Timeline

Phase	Workstream	Primary Deliverables	Status
Phase 0	Governance & Company Foundation	Program Charter; Company Profile; Organizational Chart; Asset Inventory; Data Classification; Technology Stack; Network/System Diagram; Business & Data Flows; Risk Appetite Statement; Evidence Repository	In Progress
Phase 1	Mini Compliance Program	Compliance Program Overview; NIST CSF 2.0 Control Matrix; Control Ownership; Gap Analysis; Remediation Plan	Planned
Phase 2	Enterprise Risk Management	Risk Assessment Methodology; Risk Register; Risk Scoring Model; Risk Heat Map; Mitigation Plans; Residual Risk	Planned
Phase 3	Third-Party Risk Management	Vendor Security Questionnaire; Vendor Assessment; Vendor Scorecard; Evidence Review; Risk Recommendations	Planned
Phase 4	Incident Response Governance	Incident Response Plan; Roles and Escalation Procedures; Tabletop Exercise; Incident Timeline; Incident Report; Lessons Learned	Planned
Phase 5	Technical Compliance & SOC 2	SOC 2 Control Mapping; Technical Control Validation; Evidence Collection; Control-to-Implementation Matrix	Planned
Phase 6	Compliance Reporting & Dashboard	Risk Metrics; Control Coverage; Remediation Tracking; KPIs/KRIs; Executive Compliance Dashboard	Planned
Phase 7	Internal Audit	Audit Checklist; Evidence Review; Control Testing; Audit Findings; Corrective Action Plan; Internal Audit Report	Planned
Phase 8	Integrated GRC Capstone	Consolidated GRC Program; Cross-Framework Mapping; Evidence Package; Executive Summary; Final Portfolio Case Study	Planned

Project Deliverables

The NovaForge Manufacturing GRC Program will be developed through the following phases:

Phase 0 — Governance & Company Foundation

Establish the organizational context and governance foundation required to support the GRC program.

Phase 1 — Mini Compliance Program

Develop a structured compliance program aligned with NIST Cybersecurity Framework (CSF) 2.0.

Phase 2 — Enterprise Risk Management

Identify, assess, prioritize, document, and track organizational cybersecurity risks.

Phase 3 — Third-Party Risk Management

Establish a process for evaluating and documenting cybersecurity risks associated with vendors and service providers.

Phase 4 — Incident Response Governance

Develop and test an incident response framework defining responsibilities, escalation procedures, response activities, and documentation requirements.

Phase 5 — Technical Compliance & SOC 2 Mapping

Evaluate technical security controls and map implementations and supporting evidence to applicable SOC 2 Trust Services Criteria.

Phase 6 — Compliance Reporting & Dashboard

Develop metrics, KPIs, KRIs, and dashboards to communicate risk, compliance status, control maturity, and remediation progress to leadership.

Phase 7 — Internal Audit

Conduct a simulated internal audit to evaluate control effectiveness, review evidence, document findings, and develop corrective actions.

Phase 8 — Integrated GRC Capstone

Consolidate governance, risk, compliance, vendor risk, incident response, technical control, reporting, and audit activities into a unified NovaForge Manufacturing GRC Program.

Project Risks

Risk	Mitigation
Limited staffing	Prioritize high-risk work
Budget constraints	Use risk-based approach
Scope creep	Change management process
Delayed stakeholder approval	Regular status meetings

Success Criteria

The project will be considered successful when:

- Governance documentation is complete
- Security policies are approved
- Risk register is populated
- Risk assessment is completed
- Controls are mapped to NIST CSF 2.0
- Executive dashboard is operational
- Vendor assessment process is documented
- Incident response documentation is complete

Success measures

- 100% of corporate assets inventoried.
 - All critical risks documented.
 - All policies approved by executive leadership.
 - Risk register reviewed quarterly.
 - Annual governance review completed.
-

Assumptions

- Executive leadership supports the GRC program.
 - Department managers participate in risk assessments.
 - Business units provide accurate asset information.
 - Employees complete required security awareness training.
 - Security controls are reviewed annually.
-

Constraints

- Limited cybersecurity budget
- Growing organization with evolving processes
- Compliance requirements may change over time
- Resources must be prioritized using a risk-based approach

Project Authorization

Approval of this Project Charter formally authorizes the Governance, Risk, and Compliance Program and grants the Project Manager (GRC Analyst) authority to utilize organizational resources to execute the project within the defined scope.

Dependencies

- Executive approval
- Department participation
- Asset inventory completion
- Availability of business documentation

Approval:

Name	Role	Status
Chief Executive Officer	Executive Sponsor	Approved
Chief Information Officer	Project Sponsor	Approved
GRC Analyst	Project Lead	Approved

Version	Date	Author	Description
1.0	July 2026	GRC Analyst	Initial Release